

GRC Guard AI — User Guide & Manual

Governance, Risk & Compliance platform for banking and financial institutions.

This guide covers every screen in the application: what it's for, who can use it, and how to use it. For the underlying architecture and thesis-research background, see MODEL_TRAINING_PLAN.md and VERTEX_FINETUNING.md.

1. What this platform is

GRC Guard AI helps a bank or financial institution track its compliance posture against multiple regulatory frameworks (Basel III, SOC 2, ISO 27001, NIST CSF, PCI DSS, GDPR, and others), pull live evidence from the systems it actually runs (core banking, cloud, identity, EDR), and use an AI "Brain" to answer compliance questions with explainable, auditable reasoning — with a human always in the loop before anything is officially changed.

It is **not** a black box: every AI decision comes with an explanation (attribution weights, LIME verification, counterfactual scenarios), and every AI-suggested remediation requires a human Admin to approve it before it takes effect.

2. Signing in and roles

Sign-in is handled by Clerk (email/password or SSO, depending on how your organization configured it). Every user belongs to one role, which controls what they can see and do:

Role	Can do
Viewer	Read-only. Browse dashboards, frameworks, controls, risks, reports.

Auditor	Everything a Viewer can, plus run the Compliance Scanner, query the GRC Brain, view the Mechanic queue and Attestation status. Cannot approve/reject remediations or change AI provider settings.
Editor	Everything an Auditor can, plus create/edit controls, risks, policies, and start a Vertex AI fine-tuning job.
Admin	Full access, including Settings (AI Gateway, BYOK), approving/rejecting Mechanic proposals, and managing team members.
SuperAdmin	Platform-level access across organizations (used for platform operations, not day-to-day compliance work).

New users are provisioned automatically the first time they sign in; a default department and role are assigned unless your organization's Clerk configuration sets one explicitly.

3. Dashboard (/)

The landing page. Gives a single-glance view of:

- **Regulatory Frameworks** — readiness percentage per imported framework.
- **Active Connections** — live integrations currently pulling evidence.
- **Risk Severity Matrix** — an impact × likelihood heatmap of the risk register.
- **Audit Activity Log** — a chronological feed of recent Scanner verifications.

If frameworks or integrations are empty, the dashboard tells you exactly where to go to populate them (Frameworks Library / Integrations Center).

4. Frameworks Library (/frameworks)

Browse the catalog of supported regulatory frameworks and **import** the ones your organization needs to track (Basel III is the default for banking deployments). Importing a framework pulls in its standard control set; each control's live readiness is then computed from your actual control statuses (see §5).

5. Controls Monitor (/controls)

The list of every compliance control mapped to your imported frameworks.

Each control shows:

- **Status:** Passing, Warning, or Failing.
- Which framework(s) it belongs to.
- An owner (assignable to a team member).
- Last-tested timestamp.

Control status changes automatically from two sources:

1. **Connector syncs** — an integration (e.g. Wazuh, GCP) reports a live posture check result.
2. **Mechanic approval** — an Admin approves an AI-proposed remediation (§13). Both paths write to the same audit trail (`ControlStatusEvent`), so drift (a control regressing from Passing to Failing/Warning) is always traceable to its source.

6. Risk Register (/risks)

Track organizational risks with **inherent** (before mitigation) and **residual** (after mitigation) scores, each computed as Likelihood × Impact (1–25). Click a cell in the heatmap to filter the register by severity. Each risk can be:

- **Scored** — set likelihood/impact, recompute the residual score.
- **Mapped to mitigating controls** — link one or more Controls Monitor entries that reduce this risk.
- **Stated** — Open, Mitigated, or Accepted.

7. Policies Manager (/policies)

Upload your organization's internal policy documents (PDF/text). Every

uploaded policy is automatically indexed for RAG (retrieval-augmented generation), meaning the Compliance Scanner and GRC Brain can cite specific passages from your own policies when explaining a decision — not just generic regulatory text. Policies can be routed for approval and tracked for employee digital sign-off.

8. Compliance Scanner (/scanner)

Paste a configuration snippet, transaction record, SWIFT message, or log entry and get an instant compliance verdict (COMPLIANT / VIOLATION) with:

- **Category** and matched regulatory citation.
- **XAI Feature Attribution Heatmap** — every input token colored by how much it contributed to the decision, grounded in the regulation text that was actually retrieved for this scan (not a fixed keyword list).
- **Explain with real LIME (verified)** — an opt-in, deeper check. This actually re-queries the live model with each candidate word removed and measures how much the model's own confidence shifts — a genuine perturbation-based LIME explanation, not a self-reported one. Tokens whose removal **flips the decision** are flagged "Flipped decision."
- **Recent Scans** — every scan is saved to your organization's audit log (Postgres-backed, persists across deploys) and can be reloaded here.
- **Feedback** (up/down vote) — rate a decision; feedback is stored for later model improvement (see §14).

9. GRC AI Brain (/brain)

A multi-agent conversational assistant for open-ended compliance questions ("Do we meet Basel III CET1 requirements?", "Are all endpoints covered by EDR?"). Behind the scenes, the Brain delegates to specialist agents:

Agent	Job
Compliance Auditor	Looks up frameworks/controls and their live status, and can answer questions about a connector's live posture-check results (e.g. "is GCP passing its checks?").
Risk Assessor	Reviews open risks and exposures.
Policy Researcher	Searches your uploaded policy documents (RAG).
Jurisdiction Reconciler	Flags conflicts between overlapping regulations (e.g. EU CRD/CRR vs. US Basel III) and states which one takes precedence and why.
Mechanic	Proposes a control/risk status change when asked to "fix" or "remediate" something — see §13. Never applies changes itself.

Every answer includes:

- **Feature attributions** — clearly labeled **"self-described by the LLM,**
not mathematically derived."**"** This is the model explaining its own reasoning, which is a genuinely different (and weaker) guarantee than LIME.
- **Counterfactual explanation** (EU AI Act Art. 86) — what minimal change would flip this decision.
- **Cross-jurisdictional conflicts**, if any were found.
- A **"Verify with real LIME"** button — runs the same real, perturbation-based check described in §8 against this specific answer, so you can confirm or contradict the self-reported attributions.

Conversations are saved per-user and can be revisited from the sidebar of this page.

Live status always wins. If the Compliance Auditor's live control status disagrees with something a Policy Researcher finds in an uploaded document, the live status is authoritative — a document can be stale or never reconciled against real control state. The disagreement is still reported to you as a finding, but it never silently overrides the system of record.

What the Brain cannot do: SHAP or attention-based explanations that

require access to the model's internal weights. The active model (Vertex AI Gemini) is a closed-weight hosted API — there is no internal access to build on, regardless of infrastructure. This is a disclosed limitation, not a bug.

10. Mechanic Queue (/mechanic)

Requires Admin role to approve/reject; Auditor role can view.

Every remediation the Brain's Mechanic agent proposes lands here as a **pending proposal** — it is never applied automatically. Each row shows: the target (a specific control or risk), the proposed new status, and the agent's rationale citing the evidence it saw.

- **Approve** — applies the status change immediately, and records a `ControlStatusEvent` (visible in Controls Monitor's history) so the change is traceable back to the Mechanic, exactly like a connector-driven change.

- **Reject** — discards the proposal. No state changes.

This queue is the entire "write" surface an AI agent has in this platform. Nothing else in the app lets an AI change compliance data without a human clicking Approve first.

11. Integrations Center (/integrations)

Connect real systems to pull live evidence instead of manually attesting to control status:

- **Core banking**: Apache Fineract (maker-checker, password policy, audit trail).
- **Endpoint security**: Wazuh EDR/XDR (sensor coverage, agent freshness, manager health).

- **Cloud:** AWS, GCP, Google Workspace.
- **Identity:** Okta, Auth0, Entra ID.
- **Other:** GitHub, CrowdStrike, Snyk, Jamf, Workday.

Enter read-only credentials, then **Sync** — the connector runs its posture checks against the real system and flips the mapped controls' status accordingly, recording the finding as evidence.

Each connector's individual checks (e.g. "2SV enrollment: FAIL — 6 of 7 active users not enrolled") are shown as a persistent, readable checklist on its card — not just a one-line pass/fail summary — so you can see exactly which sub-check failed and why, both right after a sync and any time you come back to this page. You can also ask the **GRC AI Brain** (§9) directly, e.g. `*"is our GCP connector passing its checks?"*` — the Compliance Auditor agent reads the same live check data.

12. Asset Inventory (/asset s) & Vendor Risk (/vendor s)

- **Asset Inventory** — catalog workstations, repositories, SaaS

applications, and database segments, and mark which are in-scope for compliance.

- **Vendor Risk (TPRM)** — onboard third-party vendors, review their security metrics, and let AI auto-populate vendor security questionnaires from uploaded vendor documentation.

People Directory (/peop le)

Review employee security parameters: background-check completion, MFA enrollment, and annual security-training sign-off status. Users are provisioned automatically from Clerk on first sign-in.

13. Evidence Library (/evidence)

The append-only ledger of everything that backs your compliance posture: automatically collected integration sync results, point-in-time compliance snapshots, and manually uploaded evidence documents (e.g. a signed policy, a pentest report). Searchable, and the source of truth an external auditor would be pointed to.

Auditor Portal (/audit)

Give an **external assessor** scoped, evidence-focused access: browse controls, download the relevant evidence, and hold a per-control comment thread with your team — without needing to grant them full platform access.

Compliance Reports (/reports)

Export framework readiness and control status as a formatted report (CSV/PDF) for board reporting or an external audit submission.

14. Attestation & Zero-Trust (/attestation)

Admin/Auditor only.

Before the platform sends any compliance data to the active AI provider, it runs a **zero-trust attestation check** and refuses to send data if it fails. This page shows the current result:

- **Attestation:** Attested / Failed, and the security level.
- **Quote Verified:** whether the workload identity check passed, and how:
- **On GCP (production):** a genuine Google-signed OIDC identity token

for this exact workload, cryptographically verified against Google's public keys — real proof this is the expected service account/project, not a self-signed claim.

- **Off GCP (local dev):** a software-simulated TPM2_QUOTE, clearly labeled as such.

- **Policy:** whether the active provider meets internal security policy (TLS encryption, zero data retention, pinned model version, approved region). Any violations or warnings are listed with the specific reason. This maps to EU AI Act Art. 9 (Risk Management) and Art. 13 (Transparency).

15. Benchmark Evaluation (/evaluation)

Runs the deterministic rule-baseline compliance engine against a **held-out** labelled test set — cases the rules were deliberately *not* authored for. Reports accuracy, precision, recall, F1, and a full confusion matrix, so the gap between "in-distribution" and genuine generalization is visible rather than hidden behind a single accuracy number.

Implementation Report (/implementation)

A project-status view mapping what's actually built against the platform's stated objectives — useful for a thesis defense, an internal readiness review, or onboarding a new team member to what exists today.

16. Notifications (/notifications)

In-app alerts for drift (a Passing control regressing), overdue tasks, and sync events. Unread count is shown as a badge in the sidebar.

17. Settings (/settings)

Admin only.

AI Gateway tab

Configure and activate the AI provider (currently Vertex AI / Gemini).

Includes:

- **Fine-tune on Vertex AI** — kicks off a real, GPU-free managed fine-tuning job on Google's fleet, trained on your perspective-labeled compliance corpus (see VERTEX_FINETUNING.md for the full pipeline). The Settings card polls status live.
- Once a fine-tuning job succeeds, **"Use as model override"** makes the tuned model the standing model — this is the **only** way to set the model override; there is no free-text field, precisely to prevent an accidental or unreviewed model swap.
- **Re-tune** — start a fresh fine-tuning run at any time.

Data Protection (BYOK) tab

Bring Your Own Key: all stored credentials (provider API keys, integration credentials) are vault-encrypted using your organization's own encryption key, never stored in plaintext.

18. Profile & Team Management (/profile)

View your own account details, and (Admin only) manage every user in your organization: add team members, assign roles/departments, and remove access.

Appendix A — Glossary

Term	Meaning
XAI	Explainable AI — showing <i>*why*</i> a decision was made, not just the decision.
LIME	Local Interpretable Model-agnostic Explanations. Here: a real, perturbation-based check that removes words and re-queries the live model to measure their actual effect on its confidence.
Counterfactual	The minimal change to the input that would flip the compliance decision.

BYOK	Bring Your Own Key — your organization controls the encryption key for stored secrets.
Zero-trust attestation	Verifying the AI provider's identity and policy compliance <i>*before*</i> sending it any data, every time — not just once at setup.
Drift	A control regressing from Passing to Warning/Failing.
Inherent vs. residual risk	Inherent = risk before any mitigation. Residual = risk remaining after mitigating controls are applied.

Appendix B — Frequently asked questions

Q: Can the AI change my compliance data on its own?

No. The only AI-initiated write path is the Mechanic queue (§13), and every proposal there requires an explicit Admin approval before anything changes.

Q: What happens if the AI provider fails attestation?

The platform refuses to send it any compliance data. This is enforced in code for every outbound AI call, not just displayed as a status page.

****Q: Why does the Brain sometimes give different answers to the same question?****

LLM-based reasoning is not perfectly deterministic. Use "Verify with real LIME" to check whether a specific answer is well-grounded, and treat repeated, high-confidence agreement across runs as stronger evidence than a single answer. See the Benchmark Evaluation page for the platform's own measured consistency data.

Q: My organization's connector shows "Error" status — what do I do?

Check the specific finding shown on the Integrations Center card (e.g. "2 admins without 2SV") — it names the exact real issue found on your live system, not a generic error. Fix the underlying issue in the source system, then re-sync.